

Security Assessment Report

Target URL: <http://testasp.vulnweb.com/Login.asp?RetURL=%2FDefault.asp%3F>

Scan ID	#9	Execution Date	2026-09-17T10:23:15.262151
Audit Status	COMPLETED	HTTP Status Code	200

Executive Severity Breakdown

CRITICAL	HIGH	MEDIUM	LOW	INFO
0	1	4	3	2

Detailed Audit Findings (10)

1. Missing Content Security Policy (CSP)			HIGH
Category	Security Headers	Affected URL	http://testasp.vulnweb.com/Login.asp?RetURL=%2FDefault.asp%3F

Description:
Content Security Policy header is not present. CSP prevents Cross-Site Scripting (XSS) and data injection attacks.

Evidence:
{ "header": "Content-Security-Policy", "status": "Missing", "owasp_link": "[https://cheatsheetseries.owasp.org/index.html](\"https://cheatsheetseries.owasp.org/index.html\")" }

Remediation Action:
Implement a strong Content-Security-Policy header restricting script execution and resource loading.

2. Missing X-Frame-Options Header			MEDIUM
Category	Security Headers	Affected URL	http://testasp.vulnweb.com/Login.asp?RetURL=%2FDefault.asp%3F

Description:
The X-Frame-Options header is absent, rendering the application potentially susceptible to Clickjacking framing attacks.

Evidence:
{ "header": "X-Frame-Options", "status": "Missing", "owasp_link": "[https://cheatsheetseries.owasp.org/index.html](\"https://cheatsheetseries.owasp.org/index.html\")" }

Remediation Action:
Configure 'X-Frame-Options: DENY' or 'X-Frame-Options: SAMEORIGIN' on HTTP responses.

3. Missing or Invalid X-Content-Type-Options Header**MEDIUM****Category**

Security Headers

Affected URL<http://testasp.vulnweb.com/Login.asp?RetURL=%2FDefault.asp%3F>**Description:**

Missing 'X-Content-Type-Options: nosniff' header allows browsers to MIME-sniff response content types, potentially executing untrusted assets.

Evidence:

```
{ "header": "X-Content-Type-Options", "value": "Missing", "owasp_link":  
"https://cheatsheetseries.owasp.org/index.html" }
```

Remediation Action:

Set 'X-Content-Type-Options: nosniff' header across all responses.

4. Missing Referrer-Policy Header**LOW****Category**

Security Headers

Affected URL<http://testasp.vulnweb.com/Login.asp?RetURL=%2FDefault.asp%3F>**Description:**

No Referrer-Policy header specified. Browsers may send full referrer URLs containing sensitive path parameters.

Evidence:

```
{ "header": "Referrer-Policy", "status": "Missing", "owasp_link":  
"https://cheatsheetseries.owasp.org/index.html" }
```

Remediation Action:

Set 'Referrer-Policy: strict-origin-when-cross-origin' or 'no-referrer'.

5. Missing Permissions-Policy Header**INFO****Category**

Security Headers

Affected URL<http://testasp.vulnweb.com/Login.asp?RetURL=%2FDefault.asp%3F>**Description:**

Permissions-Policy header is missing. Controlling browser features (geolocation, camera, microphone) is recommended.

Evidence:

```
{ "header": "Permissions-Policy", "status": "Missing", "owasp_link":  
"https://cheatsheetseries.owasp.org/index.html" }
```

Remediation Action:

Define a Permissions-Policy header to restrict access to hardware APIs.

6. Server Technology Information Leakage (X-Powered-By)**LOW****Category**

Information Disclosure

Affected URL<http://testasp.vulnweb.com/Login.asp?RetURL=%2FDefault.asp%3F>**Description:**

The server leaks detailed backend technology stack information: 'ASP.NET'.

Evidence:

```
{ "header": "X-Powered-By", "value": "ASP.NET", "owasp_link":  
"https://cheatsheetseries.owasp.org/cheatsheets/Error_Handling_Cheat_Sheet.html" }
```

Remediation Action:

Disable or strip X-Powered-By response headers in server configurations.

7. Server Software Version Disclosure**INFO****Category**

Information Disclosure

Affected URL<http://testasp.vulnweb.com/Login.asp?RetURL=%2FDefault.asp%3F>**Description:**

The Server header discloses precise software version numbers: 'Microsoft-IIS/8.5'.

Evidence:

```
{ "header": "Server", "value": "Microsoft-IIS/8.5", "owasp_link":  
"https://cheatsheetseries.owasp.org/cheatsheets/Error_Handling_Cheat_Sheet.html" }
```

Remediation Action:

Configure web server to suppress banner version details (e.g., ServerTokens Prod in Apache, server_tokens off in Nginx).

8. Cookie Missing HttpOnly Flag (ASPSESSIONIDACCRQCTA)**MEDIUM****Category**

Cookie Security

Affected URL<http://testasp.vulnweb.com/Login.asp?RetURL=%2FDefault.asp%3F>**Description:**

The cookie 'ASPSESSIONIDACCRQCTA' lacks the HttpOnly attribute, allowing client-side scripts to access cookie data via Document.cookie (increasing XSS session hijacking risk).

Evidence:

```
{ "cookie": "ASPSESSIONIDACCRQCTA=BNLIDNBBOFKPAMJADHMEMLND; path=/", "missing": "HttpOnly", "owasp_link":  
"https://cheatsheetseries.owasp.org/index.html" }
```

Remediation Action:

Append '; HttpOnly' to the Set-Cookie definition for 'ASPSESSIONIDACCRQCTA'.

9. Cookie Missing SameSite Attribute (ASPSESSIONIDACCRQCTA)**LOW****Category**

Cookie Security

Affected URL<http://testasp.vulnweb.com/Login.asp?RetURL=%2FDefault.asp%3F>**Description:**

The cookie 'ASPSESSIONIDACCRQCTA' does not specify a SameSite attribute, which exposes cross-site requests to CSRF vulnerabilities.

Evidence:

```
{ "cookie": "ASPSESSIONIDACCRQCTA=BNLIDNBBOFKPAMJADHMEMLND; path=/", "missing": "SameSite", "owasp_link": "https://cheatsheetseries.owasp.org/index.html" }
```

Remediation Action:

Append '; SameSite=Lax' or '; SameSite=Strict' to the Set-Cookie header for 'ASPSESSIONIDACCRQCTA'.

10. Cross-Site Tracing (XST) Potential - TRACE/TRACK Enabled**MEDIUM****Category**

HTTP Method Security

Affected URL<http://testasp.vulnweb.com/Login.asp?RetURL=%2FDefault.asp%3F>**Description:**

Server advertises support for HTTP TRACE/TRACK methods (TRACE). TRACE reflects raw requests back to clients and can leak sensitive headers or credentials.

Evidence:

```
{ "allowed_methods": [ "OPTIONS", "TRACE", "GET", "HEAD", "POST" ], "risky": [ "TRACE" ], "owasp_link": "https://cheatsheetseries.owasp.org/index.html" }
```

Remediation Action:

Disable HTTP TRACE and TRACK methods in web server configuration.